

Relevant Writeup - TryHackMe

Assigned To	Lâm Dương
Date Created	February 5, 2026 4:15 PM
Status	Done 🙌



Recon

Nmap

As a start, we will use nmap with the `-sV` and `-sC` flags on our target. As a reminder, these scans will do the following:

- `-sC` : equivalent to `--script=default` . Will run default script on found ports/service.
- `-sV` : probe open ports to determine service/version info.

Let's also enumerate all ports with `-p-` for good measure:

```
(root@duongpahm) - [/home/duongpahm/Downloads]
# nmap -sVC -p- 10.48.147.121
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-06 20:50 -
0500
Nmap scan report for 10.48.147.121
Host is up (0.13s latency).
Not shown: 65527 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS httpd 10.0
|_http-title: IIS Windows Server
| http-methods:
```

```

|_ Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/10.0
135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
445/tcp open microsoft-ds Windows Server 2016 Standard Ev
valuation 14393 microsoft-ds (workgroup: WORKGROUP)
3389/tcp open ms-wbt-server Microsoft Terminal Services
| rdp-ntlm-info:
| Target_Name: RELEVANT
| NetBIOS_Domain_Name: RELEVANT
| NetBIOS_Computer_Name: RELEVANT
| DNS_Domain_Name: Relevant
| DNS_Computer_Name: Relevant
| Product_Version: 10.0.14393
|_ System_Time: 2026-02-07T01:56:16+00:00
|_ssl-date: 2026-02-07T01:56:55+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=Relevant
| Not valid before: 2026-02-06T01:22:22
|_Not valid after: 2026-08-08T01:22:22
49663/tcp open http Microsoft IIS httpd 10.0
| http-methods:
|_ Potentially risky methods: TRACE
|_http-title: IIS Windows Server
|_http-server-header: Microsoft-IIS/10.0
49666/tcp open msrpc Microsoft Windows RPC
49667/tcp open msrpc Microsoft Windows RPC
Service Info: Host: RELEVANT; OS: Windows; CPE: cpe:/o:micros
oft:windows

```

And here are the host script results ran against these findings:

```

Host script results:
|_clock-skew: mean: 1h36m00s, deviation: 3h34m41s, median: 0s
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required

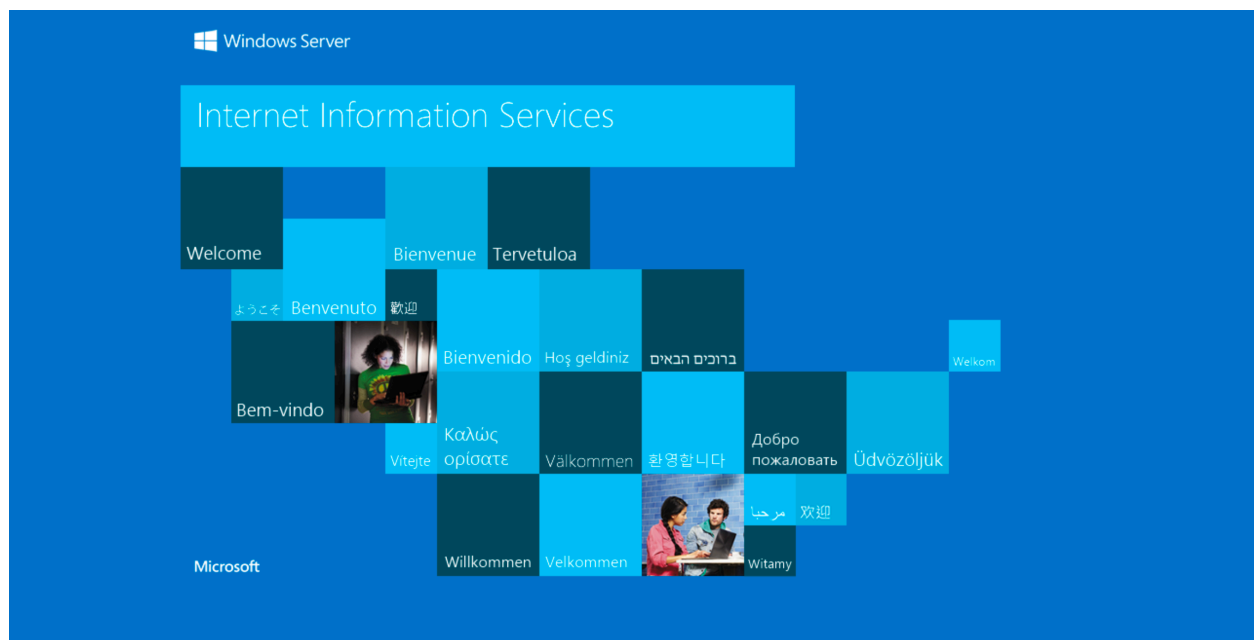
```

```
| smb-os-discovery:
|   OS: Windows Server 2016 Standard Evaluation 14393 (Windows Server 2016 Standard Evaluation 6.3)
|   Computer name: Relevant
|   NetBIOS computer name: RELEVANT\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-02-06T17:24:04-08:00
| smb2-time:
|   date: 2026-02-07T01:24:01
|_  start_date: 2026-02-07T01:22:22
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
```

We're getting a few interesting hints so far for exploitation, and also two HTTP services opened on port 80 and 49663. Let's check where this might lead us.

Website / Web service

Both of the HTTP lend us to the microsoft IIS server default page:



```
(venv)-(duongpham@duongpham)-[~]
$ dirsearch -u http://10.48.147.121/
dirsearch v0.4.3

Extensions: php, asp, aspx, jsp, html, htm | HTTP method: GET | Threads: 25 | Wordlist size: 12295
Target: http://10.48.147.121/

[21:08:43] Scanning:
[21:08:46] 404 - 2KB - /.ashx
[21:08:46] 404 - 2KB - /.asmx
[21:08:55] 403 - 32KB - /\.\\.\..\.\\.\..\.\\.\..\.etc\passwd
[21:08:57] 404 - 2KB - /admin%20/
[21:08:58] 404 - 2KB - /admin_
[21:09:07] 404 - 2KB - /asset..
[21:09:15] 400 - 3KB - /docpicker/internal_proxy/https/127.0.0.1:5043/ibm/console
[21:09:21] 404 - 2KB - /index.php..
[21:09:22] 404 - 2KB - /javafx.faces.resource ... /
[21:09:22] 400 - 3KB - /jolokia/exec/com.sun.management:type=DiagnosticCommand/help/*
[21:09:22] 400 - 3KB - /jolokia/exec/com.sun.management:type=DiagnosticCommand/compilerDirectivesAdd!/etc/passwd
[21:09:22] 400 - 3KB - /jolokia/exec/com.sun.management:type=DiagnosticCommand/jfrStart/filename=!/tmp/foo
[21:09:22] 400 - 3KB - /jolokia/exec/com.sun.management:type=DiagnosticCommand/jvmtiAgentLoad!/etc/passwd
[21:09:22] 400 - 3KB - /jolokia/exec/com.sun.management:type=DiagnosticCommand/vmLog/output=!/tmp/pwned
[21:09:22] 400 - 3KB - /jolokia/exec/java.lang:type=Memory/gc
[21:09:22] 400 - 3KB - /jolokia/exec/com.sun.management:type=DiagnosticCommand/vmSystemProperties
[21:09:22] 400 - 3KB - /jolokia/exec/com.sun.management:type=DiagnosticCommand/vmLog/disable
[21:09:22] 400 - 3KB - /jolokia/search/*:j2eeType=J2EEServer,*
[21:09:22] 400 - 3KB - /jolokia/read/java.lang:type=* HeapMemoryUsage
[21:09:22] 400 - 3KB - /jolokia/read/java.lang:type=Memory/HeapMemoryUsage/used
[21:09:23] 400 - 3KB - /jolokia/write/java.lang:type=Memory/Verbose>true
[21:09:24] 404 - 2KB - /login.wdm%2e
[21:09:33] 404 - 2KB - /rating_over..
[21:09:36] 404 - 2KB - /service.asmx
[21:09:38] 404 - 2KB - /static..
[21:09:41] 403 - 2KB - /Trace.axd
[21:09:42] 404 - 2KB - /umbraco/webresources/codeEditorSave.asmxd
[21:09:44] 404 - 2KB - /WEB-INF./
[21:09:45] 404 - 2KB - /WebResource.axd?d=LER8t9aS
```

```
(venv)(duongpham@duongpham:~)$ dirsearch -u http://10.48.147.121:49663/
```

```
dirsearch v0.4.3
Usage: dirsearch [options] URL
Options:
  -e EXTENSIONS  Extensions to search for (php, asp, aspx, jsp, html, htm) | HTTP method: GET | Threads: 25 | Wordlist size: 12295
  -t TARGET       Target URL (http://10.48.147.121:49663/)
  -w WORDLIST      Wordlist file path
  -c COOKIES      Cookies file path
  -r REFERERS     Referers file path
  -o OUTPUT        Output file path
  -q QUIET        Quiet mode (no progress bar)
  -v VERBOSE      Verbose mode (show all requests and responses)
  --help          Display this help message
  --version       Display version information
```

```
[21:14:43] Scanning:
[21:14:47] 404 - 2KB - /.ashx
[21:14:47] 404 - 2KB - /_asmx
[21:14:57] 403 - 312B - /\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.\\.etc/passwd
[21:15:01] 404 - 2KB - /admin%20/
[21:15:01] 404 - 2KB - /admin/
[21:15:13] 301 - 164B - /aspnet_client → http://10.48.147.121:49663/aspnet_client/
[21:15:13] 200 - 9B - /aspnet_client/
[21:15:13] 404 - 2KB - /asset..
[21:15:24] 400 - 3KB - /docpicker/internal_proxy/https/127.0.0.1:9043/ibm/console
[21:15:31] 404 - 2KB - /index.php.
[21:15:32] 404 - 2KB - /javax.faces.resource ... /
[21:15:32] 400 - 3KB - /jotokia/exec/com.sun.management:type=DiagnosticCommand/vmLog/output=/tmp/pwn/
[21:15:32] 400 - 3KB - /jotokia/exec/com.sun.management:type=DiagnosticCommand/jvmtiAgentLoad!/etc/passwd
[21:15:32] 400 - 3KB - /jotokia/exec/com.sun.management:type=DiagnosticCommand/jfrStart/filename=/tmp/foo
[21:15:32] 400 - 3KB - /jotokia/exec/com.sun.management:type=DiagnosticCommand/vmLog/disable
[21:15:32] 400 - 3KB - /jotokia/exec/com.sun.management:type=DiagnosticCommand/help/*
[21:15:32] 400 - 3KB - /jotokia/exec/com.sun.management:type=DiagnosticCommand/compilerDirectivesAdd!/etc/passwd
[21:15:32] 400 - 3KB - /jotokia/exec/java.lang:type=Memory/gc
[21:15:32] 400 - 3KB - /jotokia/read/java.lang:type=*//HeapMemoryUsage
[21:15:32] 400 - 3KB - /jotokia/exec/com.sun.management:type=DiagnosticCommand/vmSystemProperties
[21:15:32] 400 - 3KB - /jotokia/search/*:j2eeType=J2EEServer,*
[21:15:32] 400 - 3KB - /jotokia/read/java.lang:type=Memory/HeapMemoryUsage/used
[21:15:32] 400 - 3KB - /jotokia/write/java.lang:type=Memory/Verbose>true
[21:15:34] 404 - 2KB - /login.wdm%2e
[21:15:44] 404 - 2KB - /rating_over.
[21:15:46] 404 - 2KB - /service.asmx
[21:15:49] 404 - 2KB - /static..
[21:15:52] 403 - 2KB - /Trace.axd
[21:15:52] 404 - 2KB - /umbraco/webservices/codeEditorSave.aspx
[21:15:54] 404 - 2KB - /WEB-INF./
[21:15:55] 404 - 2KB - /WebResource.axd?d=LER8t9aS
```

```
Task Completed
```

Relevant Writeup - TryHackMe

SMB enumeration

At first, nmap scripting targeting SMB protocols seem to lead us to something juicy: perhaps this target is vulnerable to EternalBlue!

```
nmap -p 445 --script smb-protocols 10.48.147.121
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-06 20:50 -
0500
Nmap scan report for 10.48.147.121
Host is up (0.044s latency).
```

```
PORT      STATE SERVICE
445/tcp   open  microsoft-ds
```

Host script results:

```
| smb-protocols:
|   dialects:
|     NT LM 0.12 (SMBv1) [dangerous, but default]
|     2.02
|     2.10
|     3.00
|     3.02
|_    3.11
```

```
Nmap done: 1 IP address (1 host up) scanned in 8.57 seconds
```

That would be too good to be true right? Well, that's because it is. SMB1 is disabled:

```
smbclient -N -L \\\\10.48.147.121
```

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC

```
nt4wrksv      Disk
SMB1 disabled -- no workgroup available
```

However, the `nt4wrksv` share is quite unusual and seem to be worth exploring.

Relevant findings for exploitation

So far, our main lead is exploiting samba and maybe find some pieces of information that might lead us to a reverse shell.

Exploitation

Since SMB1 is disabled, EternalBlue is not even worth exploring for this target. Let's connect to `nt4wrksv` with an anonymous connection:

```
(root@duongpahm) - [/home/duongpahm]
# smbclient //10.48.147.121/nt4wrksv
Password for [WORKGROUP\root]:
Try "help" to get a list of possible commands.
smb: \> ls
.                               D              0   Sat Jul 25
17:46:04 2020
..                              D              0   Sat Jul 25
17:46:04 2020
  passwords.txt                 A            98   Sat Jul 25
11:15:33 2020

7735807 blocks of size 4096. 4929144 blocks a
vailable
smb: \> get passwords.txt
```

We quickly get our eyes on a `passwords.txt` file, immediately accessible on this share with `more passwords.txt`

```
(duongpahm@duongpahm) - [~]
$ cat passwords.txt
[User Passwords - Encoded]
```

```
Qm9iIC0gIVBAJCRXMHJEITEyMw==
```

```
QmlsbCAtIEp1dzRubmFNNG40MjA2OTY5NjkhJCQk
```

Base64 encoded... Easy fix, let's decode those strings:

```
(duongpahm@duongpahm) - [~]
```

```
$ echo "Qm9iIC0gIVBAJCRXMHJEITEyMw==" | base64 -d
```

```
Bob - !P@$$W0rD!123
```

```
(duongpahm@duongpahm) - [~]
```

```
$ echo "QmlsbCAtIEp1dzRubmFNNG40MjA2OTY5NjkhJCQk" | base64 -d
```

```
Bill - Juw4nnaM4n420696969!$$$
```

Connecting to SMB with those credentials works, but the permissions for those accounts are similar to anonymous connections. Disappointing. Bill and Bob shall not help us any further, as this seems to be another red herring.

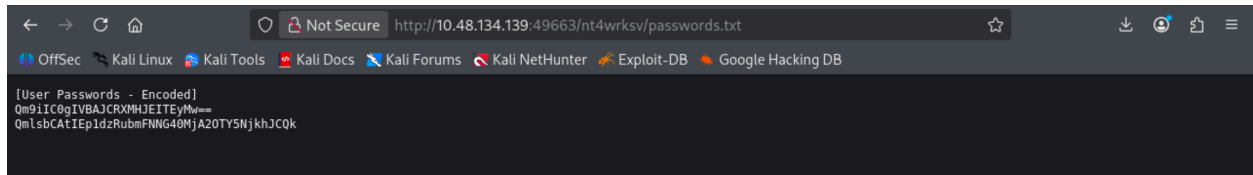
```
(duongpahm@duongpahm)-[~]
$ smbmap -u Bob -p '!P@$$W0rD!123' -H 10.48.190.76

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

Relevant 10.48.190.76 50min 13s
[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[+] IP: 10.48.190.76:445 Name: 10.48.190.76 Status: Authenticated
Disk Permissions Comment
ADMIN$ NO ACCESS Remote Admin
C$ NO ACCESS Default share
IPC$ READ ONLY Remote IPC
nt4wrksv READ, WRITE
[*] Closed 1 connections
```

After some additional attempts on SMB, I gave up to focus on web services yet again. Surely there has to be something more about them...



And there is! Turns out all of `nt4wrksv` contents are directly accessible through HTTP on port 49663. We might be able to get a reverse shell exactly the same way.

Since those web services are all powered by IIS servers, `.aspx` ought to be our best option as payload output: